CTA Security Assessment Report

Security Assessment Report (SAR)

Community Tech Aid (CTA)

System: Community Tech Aid, a consumer-facing AI tech-support web application **Legal entity:** eBiz Market, LLC (Idaho), single owner and operator, no employees **Assumed business name:** Community Tech Aid **Primary URL:** https://communitytechaid.ai **Framework:** NIST SP 800-53 Revision 5, LOW baseline; assessment procedures per NIST SP 800-53A Rev 5 **Document type:** Security assessment report for a cybersecurity portfolio **Assessment period:** 2026-07-27 **Report date:** 2026-07-27 **Assessor:** System owner (eBiz Market, LLC), acting as self-assessor **Assessment type:** Self-assessment. Not independent. See Section 3.

Documents assessed:

Artifact	Version / date	Role in this assessment
NIST SP 800-53 Rev 5 LOW Baseline Control Implementation Statements (the SSP)	prepared and revised 2026-07-27	Statement of implementation under assessment
Community Tech Aid Security Policy Manual	v1.0, effective 2026-07-27	Policy evidence for the family "-1" controls

> *This report records the results of assessing the controls asserted in the SSP. It states what was examined, what was tested, and where the assertion holds or does not. It does not restate the implementation; it evaluates it. Where the assessor's conclusion differs from the status claimed in the SSP, the difference is stated plainly in Section 6.*

1. Purpose

This report documents the assessment of the security controls implemented for Community Tech Aid against the NIST SP 800-53 Rev 5 LOW baseline. Its purposes are to determine the extent to which each control is implemented correctly, operating as intended, and producing the desired outcome; to record the resulting weaknesses as findings; and to produce a plan of action and milestones (POA&M) that assigns a remediation approach and a target date to each open weakness.

The system is a private commercial application. There is no external authorizing official and no authority to operate is being sought. The owner is the accountable party and the acceptor of residual risk. This report exists so that the acceptance is informed and documented rather than implicit.

2. Scope

The assessment covers the 136 control statements enumerated in the SSP, spanning 17 control families plus the withdrawn control PE-7, which is recorded for completeness. Program Management (PM) controls are organization-wide and out of scope, consistent with the SSP.

The assessment boundary is the boundary defined in SSP Section 2: the CTA frontend, the edge functions, the client access logic, the application database and its tables, the authentication configuration, and the application data. Platform components supplied by Lovable Cloud and Cloudflare are in the boundary as inherited infrastructure. Anthropic, Stripe, Resend, Proton, and Zoom are external interconnections and were assessed only as to how the system exchanges data with them, not as to their own internal control environments.

Out of scope: the internal security posture of any service provider; the secondary and defensive domains; end-user devices; and any eBiz Market, LLC system other than CTA.

3. Assessor Independence and Limitations

This is a self-assessment. The owner authored the SSP, implemented the controls, and performed this assessment. There is no separation between the implementer and the assessor, and no independent party reviewed the results. Under NIST SP 800-53A this is a valid assessment type for a LOW-impact system, and independence is not required at LOW. It is stated here because the degree of independence is part of the result, and a reader is entitled to weight the conclusions accordingly.

Four further limitations bound what this assessment can claim.

Managed-platform opacity. The backend is a Lovable Cloud managed Supabase instance. The owner holds no service role key, no direct database URL, and no separate Supabase dashboard. Controls that depend on configuration the Lovable editor does not expose could not be independently verified by the assessor. They are marked Satisfied (Inherited) on the basis of provider representation, not on the basis of testing.

No provider attestations obtained. No SOC 2 report or equivalent was obtained for Lovable, Cloudflare, Stripe, Anthropic, or Resend during the assessment period. All 25 inherited controls therefore rest on provider public documentation and standard terms of service. This is the single largest evidentiary weakness in the report.

No independent scanning of the running system. Testing consisted of code review, database and configuration inspection, dependency scanning, and functional verification of specific access paths. No external vulnerability scan, no penetration test, and no dynamic application security test was performed.

Point-in-time. The results describe the system as of 2026-07-27. Several controls were remediated during the assessment period; those are assessed in their post-remediation state and the remediation is noted in the result.

---

4. Assessment Methodology

Assessment methods follow NIST SP 800-53A Rev 5.

Method	Abbreviation	What it meant in this assessment
Examine	E	Inspection of the SSP, the policy manual, application source, edge-function source, database schema and grants, RLS policies, provider console configuration, and public site content
Interview	I	Structured self-interview of the owner as the sole role holder, recorded through the implementation statements and the gap declarations in the SSP
Test	T	Functional exercise of a control to observe actual behavior, including the access-gate tests, the audit-write denial tests, the signup enforcement tests, the rate-limit checks, and the dependency scan

Every control received Examine and Interview. Test was applied to 24 controls where a behavior could be exercised and observed directly. The Method column in Section 5 records which methods were applied to each control.

Determination values. Each control received one of four results.

- **Satisfied.** The control is implemented, the evidence supports the implementation statement, and no weakness was identified.
- **Satisfied (Inherited).** The control is supplied by a named provider and the owner relies on it. The determination rests on provider representation, not on assessor testing. See the limitation in Section 3.
- **Other Than Satisfied.** One or more elements of the control are not implemented, not documented, or not verifiable. Every Other Than Satisfied result maps to a finding in Section 7.
- **Not Applicable.** The control does not apply to this system for a stated reason, most often the absence of a workforce, a facility, or removable media.

Risk rating scale. Findings are rated Moderate or Low against a system categorized LOW for confidentiality, integrity, and availability, processing LOW-impact PII, holding no cardholder data, no federal information, and no health records. No finding rated High. A finding rated Moderate is one where the weakness could plausibly result in loss of availability, loss of PII confidentiality, or an inability to detect or recover from an event. A finding rated Low is one where the weakness is primarily documentary, or where compensating conditions substantially limit the exposure.

---

5. Assessment Results by Control

Results for all 136 assessed controls. The Finding column references Section 7.

AC - Access Control

Control	Control Name	Method	Assessment Objects Examined	Result	Finding
AC-1	Policy and Procedures	E, I	cta-policies.md (AC - Access Control Policy); Supabase Auth configuration; RLS policies; `ChatAccessGate`	Satisfied	-
AC-2	Account Management	E, I, T	Supabase Auth; `profiles` table and signup trigger; `user_roles` table	Other Than Satisfied	SAR-13
AC-3	Access Enforcement	E, I, T	RLS policies; `ChatAccessGate`; `validatePaidTokenWithServer()`; `supabase/functions/chat/index.ts`; retired `validate-beta`; SECURITY	Satisfied	-

			DEFINER EXEC…		
AC-7	Unsuccessful Logon Attempts	E, I	`log-auth-event` edge function; `auth_events` table; Supabase Auth rate limiting	Other Than Satisfied	SAR-16
AC-8	System Use Notification	E, I, T	System-use notice on `Login.tsx` and `Signup.tsx` linking to `/terms`; `/terms`, `/privacy`	Satisfied	-
AC-14	Permitted Actions Without Identification or Authentication	E, I, T	Public route set; `ChatAccessGate`; Supabase Auth with anonymous sign-in disabled	Satisfied	-
AC-17	Remote Access	E, I, T	Cloudflare edge TLS; provider consoles; multifactor authentication on all administrative provider accounts	Satisfied	-
AC-18	Wireless Access	E, I	Fully cloud-hosted architecture; no owned facility	Not Applicable	-
AC-19	Access Control for Mobile Devices	E, I	No owned or managed mobile device fleet	Not Applicable	-
AC-20	Use of External Systems	E, I	Section 2.3 and Section 5; edge-function integrations	Other Than Satisfied	SAR-14
AC-22	Publicly Accessible Content	E, I	Public route set; single-owner publishing	Satisfied	-

AT - Awareness and Training

Control	Control Name	Method	Assessment Objects Examined	Result	Finding
AT-1	Policy and Procedures	E, I	cta-policies.md (AT - Awareness and Training Policy); single-operator business	Satisfied	-
AT-2	Literacy Training and Awareness	E, I	Single-operator business; security practices in the codebase	Not Applicable	-
AT-3	Role-based Training	E, I	Single-operator business	Not Applicable	-
AT-4	Training Records	E, I	Single-operator business	Not Applicable	-

AU - Audit and Accountability

Control	Control Name	Method	Assessment Objects Examined	Result	Finding
AU-1	Policy and Procedures	E, I	cta-policies.md (AU - Audit and Accountability Policy); `log-auth-event`; `log-analytics`; `auth_events`	Satisfied	-
AU-2	Event Logging	E, I, T	`auth_events` table; `log-auth-event`; `log-analytics`; Lovable Cloud platform logs	Other Than Satisfied	SAR-02
AU-3	Content of Audit Records	E, I	`auth_events` schema; `log-auth-event`	Other Than Satisfied	SAR-02
AU-4	Audit Log Storage Capacity	E, I	Lovable Cloud platform; `auth_events` 90-day pg_cron purge	Satisfied (Inherited)	-
AU-5	Response to Audit Logging Process Failures	E, I, T	`supabase/functions/_shared/security-alert.ts` (Resend alert helper); try/catch alerting in `log-auth-event` and `log-analytics`	Other Than Satisfied	SAR-02
AU-6	Audit Record Review, Analysis, and Reporting	E, I, T	`count_recent_login_fails(ip, 15)` RPC; Resend alerting in `log-auth-event`; `auth_events`; Cloudflare Analytics	Other Than Satisfied	SAR-02
AU-8	Time Stamps	E, I	Postgres timestamps; Lovable Cloud platform time	Satisfied (Inherited)	-
AU-9	Protection of Audit Information	E, I, T	`REVOKE INSERT` on `auth_events` from `anon`/`authenticated`; RLS insert-deny; JWT-derived identity in `log-auth-event`; Lovable Cloud managed acce…	Satisfied	-
AU-11	Audit Record Retention	E, I, T	`auth_events` 90-day pg_cron purge; Lovable Cloud defaults	Satisfied	-
AU-12	Audit Record Generation	E, I, T	`log-auth-event`; `log-analytics`; Lovable Cloud platform logs	Other Than Satisfied	SAR-02

CA - Assessment, Authorization, and Monitoring

Control	Control Name	Method	Assessment Objects Examined	Result	Finding
CA-1	Policy and Procedures	E, I	cta-policies.md (CA - Assessment, Authorization, and Monitoring Policy); this SSP	Satisfied	-
CA-2	Control Assessments	E, I	This SSP; Section 9	Other Than Satisfied	SAR-12
CA-3	Information Exchange	E, I	Section 2.3; Section 5; provider terms of service	Other Than Satisfied	SAR-14
CA-5	Plan of Action and Milestones	E, I	Known Gaps section of this SSP	Other Than Satisfied	SAR-12
CA-6	Authorization	E, I	This SSP; single-owner accountability	Other Than	SAR-12

CA-6	Authorization	E, I	This SSP; single-owner accountability	Other Than Satisfied	SAR-12
CA-7	Continuous Monitoring	E, I	Cloudflare Analytics; `auth_events`; absence of a monitoring strategy	Other Than Satisfied	SAR-03
CA-9	Internal System Connections	E, I	RLS policies; Lovable Cloud managed environment	Other Than Satisfied	SAR-17

CM - Configuration Management

Control	Control Name	Method	Assessment Objects Examined	Result	Finding
CM-1	Policy and Procedures	E, I	cta-policies.md (CM - Configuration Management Policy); Supabase Auth settings; redirect allowlist; RLS	Satisfied	-
CM-2	Baseline Configuration	E, I	Lovable project state; edge functions; database schema	Other Than Satisfied	SAR-08
CM-4	Impact Analyses	E, I	Section 9; single-operator change process	Other Than Satisfied	SAR-08
CM-5	Access Restrictions for Change	E, I	Multifactor authentication on all administrative provider accounts; edge-function secret store; single owner	Satisfied	-
CM-6	Configuration Settings	E, I, T	Supabase Auth settings (More > Cloud > Users); redirect allowlist; `log-analytics` CORS allowlist; RLS	Other Than Satisfied	SAR-08
CM-7	Least Functionality	E, I, T	Route gating; disabled anonymous sign-in; retired `validate-beta` function; `empty-disk-1010` Worker (0 invocations, unconfirmed)	Other Than Satisfied	SAR-08
CM-8	System Component Inventory	E, I	Section 2 of this SSP	Other Than Satisfied	SAR-08
CM-10	Software Usage Restrictions	E, I	Provider terms of service; Section 2	Other Than Satisfied	SAR-18
CM-11	User-installed Software	E, I	Hosted web application architecture	Satisfied	-

CP - Contingency Planning

Control	Control Name	Method	Assessment Objects Examined	Result	Finding
CP-1	Policy and Procedures	E, I	cta-policies.md (CP - Contingency Planning Policy); Lovable Cloud Database view	Satisfied	-
CP-2	Contingency Plan	E, I	Absence of a contingency plan; inherited platform availability	Other Than Satisfied	SAR-04
CP-3	Contingency Training	E, I	Single-operator business; no contingency plan	Not Applicable	-
CP-4	Contingency Plan Testing	E, I	Absence of a contingency plan; untested restore	Other Than Satisfied	SAR-04
CP-9	System Backup	E, I	Lovable Cloud Database view (platform backups); no independent backup or tested restore	Other Than Satisfied	SAR-05
CP-10	System Recovery and Reconstitution	E, I	Lovable Cloud platform recovery; absence of a documented procedure	Other Than Satisfied	SAR-04

IA - Identification and Authentication

Control	Control Name	Method	Assessment Objects Examined	Result	Finding
IA-1	Policy and Procedures	E, I	cta-policies.md (IA - Identification and Authentication Policy); Supabase Auth; registration form	Satisfied	-
IA-2	Identification and Authentication (Organizational Users)	E, I	Multifactor authentication on all administrative provider accounts; single-owner access	Satisfied	-
IA-4	Identifier Management	E, I	Supabase Auth; `profiles` (id FK auth.users); signup trigger	Satisfied	-
IA-5	Authenticator Management	E, I, T	`supabase/functions/secure-signup/index.ts` (server-side 12-char minimum and HIBP); Supabase `password_hibp_enabled`; Resend magic-link recovery; S...	Other Than Satisfied	SAR-01
IA-6	Authentication Feedback	E, I	Masked password fields; Supabase Auth flows	Satisfied	-
IA-7	Cryptographic Module Authentication	E, I	Supabase Auth; Cloudflare TLS	Satisfied (Inherited)	-
IA-8	Identification and Authentication (Non-organizational Users)	E, I, T	Supabase Auth; anonymous sign-in disabled; `ChatAccessGate`	Satisfied	-
IA-11	Re-authentication	E, I, T	`useIdleLogout` hook; chat idle timeout	Satisfied	-

IR - Incident Response

Control	Control Name	Method	Assessment Objects Examined	Result	Finding
IR-1	Policy and Procedures	E, I	cta-policies.md (IR - Incident Response Policy); Section 9 finding	Satisfied	-
IR-2	Incident Response Training	E, I	Single-operator business; no IR plan	Not Applicable	-
IR-4	Incident Handling	E, I	Section 9, Findings and Remediation	Other Than Satisfied	SAR-06
IR-5	Incident Monitoring	E, I	`auth_events`; Cloudflare Analytics; no alerting	Other Than Satisfied	SAR-06
IR-6	Incident Reporting	E, I	Single-operator business; absence of a reporting procedure	Other Than Satisfied	SAR-06
IR-7	Incident Response Assistance	E, I	Provider support channels; no dedicated IR assistance	Other Than Satisfied	SAR-06
IR-8	Incident Response Plan	E, I	Absence of an IR plan	Other Than Satisfied	SAR-06

MA - Maintenance

Control	Control Name	Method	Assessment Objects Examined	Result	Finding
MA-1	Policy and Procedures	E, I	cta-policies.md (MA - Maintenance Policy); provider-managed platforms	Satisfied	-
MA-2	Controlled Maintenance	E, I	Lovable Cloud and Cloudflare managed maintenance; Lovable editor for application changes	Satisfied (Inherited)	-
MA-4	Nonlocal Maintenance	E, I	Multifactor authentication on all administrative provider accounts; provider consoles over HTTPS	Satisfied	-
MA-5	Maintenance Personnel	E, I	Single owner; provider-employed platform staff	Satisfied	-

MP - Media Protection

Control	Control Name	Method	Assessment Objects Examined	Result	Finding
MP-1	Policy and Procedures	E, I	cta-policies.md (MP - Media Protection Policy); cloud-only storage	Satisfied	-
MP-2	Media Access	E, I	Cloud-only storage; Lovable Cloud managed media	Satisfied (Inherited)	-
MP-6	Media Sanitization	E, I	Provider data-center media handling; logical deletion in Postgres	Satisfied (Inherited)	-
MP-7	Media Use	E, I	Cloud-only architecture	Not Applicable	-

PE - Physical and Environmental Protection

Control	Control Name	Method	Assessment Objects Examined	Result	Finding
PE-1	Policy and Procedures	E, I	cta-policies.md (PE - Physical and Environmental Protection Policy); no owned facility	Satisfied	-
PE-2	Physical Access Authorizations	E, I	Provider-managed data centers	Satisfied (Inherited)	-
PE-3	Physical Access Control	E, I	Provider-managed data centers	Satisfied (Inherited)	-
PE-4	Access Control for Transmission	E, I	Provider infrastructure; see SC-8	Satisfied (Inherited)	-
PE-5	Access Control for Output Devices	E, I	No owned output devices	Not Applicable	-
PE-6	Monitoring Physical Access	E, I	Provider-managed data centers	Satisfied (Inherited)	-
PE-7	(Withdrawn)	E, I	NIST SP 800-53 Rev 5 control catalog	Not Applicable	-
PE-8	Visitor Access Records	E, I	Provider-managed data centers	Satisfied (Inherited)	-
PE-12	Emergency Lighting	E, I	Provider-managed data centers	Satisfied (Inherited)	-
PE-13	Fire Protection	E, I	Provider-managed data centers	Satisfied (Inherited)	-
PE-14	Environmental Controls	E, I	Provider-managed data centers	Satisfied (Inherited)	-
PE-15	Water Damage Protection	E, I	Provider-managed data centers	Satisfied (Inherited)	-
PE-16	Delivery and Removal	E, I	Provider-managed data centers	Satisfied (Inherited)	-

PL - Planning

Control	Control Name	Method	Assessment Objects Examined	Result	Finding
PL-1	Policy and Procedures	E, I	cta-policies.md (PL - Planning Policy); this SSP; `/terms`	Satisfied	-
PL-2	System Security and Privacy Plans	E, I	This SSP; `/privacy`	Satisfied	-
PL-4	Rules of Behavior	E, I	`/terms`	Satisfied	-
PL-10	Baseline Selection	E, I	Section 1; this SSP	Satisfied	-
PL-11	Baseline Tailoring	E, I	Per-control Status and rationale throughout this SSP	Satisfied	-

PS - Personnel Security

Control	Control Name	Method	Assessment Objects Examined	Result	Finding
PS-1	Policy and Procedures	E, I	cta-policies.md (PS - Personnel Security Policy); single-operator business	Satisfied	-
PS-2	Position Risk Designation	E, I	Single-operator business	Not Applicable	-
PS-3	Personnel Screening	E, I	Single-operator business	Not Applicable	-
PS-4	Personnel Termination	E, I	Single-operator business	Not Applicable	-
PS-5	Personnel Transfer	E, I	Single-operator business	Not Applicable	-
PS-6	Access Agreements	E, I	Two accounts (owner and marketing collaborator); collaborator agreement status unconfirmed	Other Than Satisfied	SAR-13
PS-7	External Personnel Security	E, I	Provider terms of service	Satisfied (Inherited)	-
PS-8	Personnel Sanctions	E, I	Single-operator business	Not Applicable	-
PS-9	Position Descriptions	E, I	Single-operator business	Not Applicable	-

RA - Risk Assessment

Control	Control Name	Method	Assessment Objects Examined	Result	Finding
RA-1	Policy and Procedures	E, I	cta-policies.md (RA - Risk Assessment Policy); Section 1 categorization; HIBP check	Satisfied	-
RA-2	Security Categorization	E, I	Section 1 categorization	Other Than Satisfied	SAR-07
RA-3	Risk Assessment	E, I	Known Gaps section; Section 9	Other Than Satisfied	SAR-07
RA-5	Vulnerability Monitoring and Scanning	E, I, T	Lovable dependency scan (2026-07-27, 13 to 6); package upgrades and npm overrides; HIBP check; provider-managed platform patching	Other Than Satisfied	SAR-10
RA-7	Risk Response	E, I	Section 9 Findings and Remediation Log; Known Gaps section	Other Than Satisfied	SAR-07

SA - System and Services Acquisition

Control	Control Name	Method	Assessment Objects Examined	Result	Finding
SA-1	Policy and Procedures	E, I	cta-policies.md (SA - System and Services Acquisition Policy); provider subscriptions	Satisfied	-
SA-2	Allocation of Resources	E, I	Active provider subscriptions	Satisfied	-
SA-3	System Development Life Cycle	E, I	Lovable build environment; Section 9	Other Than Satisfied	SAR-15
SA-4	Acquisition Process	E, I	Provider terms of service	Other Than Satisfied	SAR-14
SA-5	System Documentation	E, I	This SSP; Lovable project; provider docs; `/terms`, `/privacy`	Other Than Satisfied	SAR-15
SA-8	Security and Privacy Engineering Principles	E, I, T	`chat` edge function; edge-function secrets; RLS; `log-analytics` CORS allowlist; redirect allowlist; `validatePaidTokenWithServer()`	Satisfied	-
SA-9	External System Services	E, I	Section 2.3; Section 5; provider terms	Other Than Satisfied	SAR-14
SA-22	Unsupported System Components	E, I	Lovable dependency scanner (version and vulnerability enumeration); 2026-07-27 remediation; current provider services	Other Than Satisfied	SAR-11

SC - System and Communications Protection

Control	Control Name	Method	Assessment Objects Examined	Result	Finding
SC-1	Policy and Procedures	E, I	cta-policies.md (SC - System and Communications Protection Policy); Cloudflare edge TLS; RLS; edge-function secret store	Satisfied	-
SC-5	Denial-of-service Protection	E, I, T	Cloudflare edge; `chat` edge-function message cap; `validate-magic-token` (10/min/IP); `send-contact` (3/min/IP)	Satisfied (Inherited)	-

SC-7	Boundary Protection	E, I	Cloudflare edge; `ChatAccessGate`; `log-analytics` CORS allowlist; redirect allowlist; `validatePaidTokenWithServer()`	Other Than Satisfied	SAR-09
SC-8	Transmission Confidentiality and Integrity	E, I, T	Cloudflare edge TLS; HTTPS to all external services	Satisfied	-
SC-12	Cryptographic Key Establishment and Management	E, I	Cloudflare and Supabase key management; edge-function secret store	Satisfied (Inherited)	-
SC-13	Cryptographic Protection	E, I	Cloudflare TLS; Supabase Auth hashing	Satisfied (Inherited)	-
SC-15	Collaborative Computing Devices and Applications	E, I	Email handoff; Zoom (external); no in-system collaborative devices	Not Applicable	-
SC-20	Secure Name/Address Resolution Service (Authoritative Source)	E, I	Cloudflare authoritative DNS; DNSSEC status unconfirmed	Other Than Satisfied	SAR-20
SC-21	Secure Name/Address Resolution Service (Recursive or Caching Resolver)	E, I	No system-operated resolver	Not Applicable	-
SC-22	Architecture and Provisioning for Name/Address Resolution Service	E, I	Cloudflare DNS infrastructure	Satisfied (Inherited)	-
SC-28	Protection of Information at Rest	E, I, T	Lovable Cloud managed Postgres; RLS policies	Satisfied (Inherited)	-
SC-39	Process Isolation	E, I	Lovable Cloud and Cloudflare runtime isolation	Satisfied (Inherited)	-

SI - System and Information Integrity

Control	Control Name	Method	Assessment Objects Examined	Result	Finding
SI-1	Policy and Procedures	E, I	cta-policies.md (SI - System and Information Integrity Policy); `spam_attempts`; `suppression_list`; `auth_events`	Satisfied	-
SI-2	Flaw Remediation	E, I, T	Provider patching; Section 9 Remediation Log 2026-07-27; Lovable editor; Lovable dependency scanner	Other Than Satisfied	SAR-10
SI-3	Malicious Code Protection	E, I	`spam_attempts` table; `suppression_list`; text-only input; provider infrastructure	Other Than Satisfied	SAR-19
SI-4	System Monitoring	E, I	Cloudflare Analytics; `auth_events`; `count_recent_login_fails` RPC; `_shared/security-alert.ts` Resend alerts	Other Than Satisfied	SAR-03
SI-5	Security Alerts, Advisories, and Directives	E, I	Provider notifications; no formal advisory process	Other Than Satisfied	SAR-03
SI-12	Information Management and Retention	E, I, T	Daily `pg_cron` purge jobs: `auth_events` 90d, `chat_sessions`/`contact_messages`/`demographics_submissions` 180d; `/privacy`	Satisfied	-

SR - Supply Chain Risk Management

Control	Control Name	Method	Assessment Objects Examined	Result	Finding
SR-1	Policy and Procedures	E, I	cta-policies.md (SR - Supply Chain Risk Management Policy); Section 2 component set	Satisfied	-
SR-2	Supply Chain Risk Management Plan	E, I	Section 2; absence of an SCRM plan	Other Than Satisfied	SAR-14
SR-3	Supply Chain Controls and Processes	E, I, T	Provider set in Section 2	Other Than Satisfied	SAR-14
SR-5	Acquisition Strategies, Tools, and Methods	E, I	Provider subscriptions and terms	Other Than Satisfied	SAR-14
SR-8	Notification Agreements	E, I	Provider terms of service	Satisfied (Inherited)	-
SR-10	Inspection of Systems or Components	E, I	Constrained Lovable Cloud access; no direct component access	Satisfied (Inherited)	-
SR-11	Component Authenticity	E, I	Direct provider relationships through official channels	Other Than Satisfied	SAR-14
SR-12	Component Disposal	E, I	Provider data-center disposal; logical data deletion; `empty-disk-1010` (unconfirmed)	Other Than Satisfied	SAR-20

6. Summary of Results

6.1 Results by family

Family	Total	Satisfied	Satisfied (Inherited)	Other Than Satisfied	Not Applicable
AC - Access Control	11	6	0	3	2
AT - Awareness and Training	4	1	0	0	3
AU - Audit and Accountability	10	3	2	5	0
CA - Assessment, Authorization, and Monitoring	7	1	0	6	0
CM - Configuration Management	9	3	0	6	0
CP - Contingency Planning	6	1	0	4	1
IA - Identification and Authentication	8	6	1	1	0
IR - Incident Response	7	1	0	5	1
MA - Maintenance	4	3	1	0	0
MP - Media Protection	4	1	2	0	1
PE - Physical and Environmental Protection	13	1	10	0	2
PL - Planning	5	5	0	0	0
PS - Personnel Security	9	1	1	1	6
RA - Risk Assessment	5	1	0	4	0
SA - System and Services Acquisition	8	3	0	5	0
SC - System and Communications Protection	12	2	6	2	2
SI - System and Information Integrity	6	2	0	4	0
SR - Supply Chain Risk Management	8	1	2	5	0
Total	**136**	**42**	**25**	**51**	**18**

6.2 Interpretation

Of 136 assessed controls, 67 are Satisfied (42 owner-implemented and 25 inherited), 18 are Not Applicable, and 51 are Other Than Satisfied. Read without context, 51 open controls against 136 looks poor. Read against what the system is, the distribution is more informative than the count.

The Satisfied results cluster in the technical control families the owner actually operates: access enforcement, identification and authentication, planning, and the policy and procedure ("-1") controls across all 17 families, which the policy manual closes. Row Level Security, server-side access gating, disabled anonymous sign-in, JWT-derived audit identity, revoked EXECUTE on security-definer functions, and server-side free-tier enforcement are implemented and were tested.

The Other Than Satisfied results cluster in the process and documentation families: contingency planning, incident response, continuous monitoring, risk assessment, configuration management, and supply chain. This is the signature of a system that was built securely and governed informally. Nothing in the assessment suggests the owner cannot operate these controls; the finding is that they are not written down, not scheduled, and not tested.

Two structural conditions drive a large share of the open results. First, 25 controls are inherited and none are backed by a provider attestation, so their Satisfied determination is weaker than the label suggests. Second, the managed-platform model removes the owner's ability to configure or verify several controls at all, which converts what would be an implementation decision into an accepted constraint.

6.3 Where the assessor's determination differs from the SSP

Three determinations in this report are less favorable than the status claimed in the SSP. They are recorded here rather than silently reconciled.

Control	SSP status	Assessor result	Basis for the difference
CP-9	Inherited (platform backups) with owner verification a Gap	Other Than Satisfied	The inherited portion is real, but the owner residual, an independent backup and a tested restore, is not implemented. A control whose owner-responsible element is absent is not Satisfied, and the SSP's own gap list agrees.
CP-10	Inherited (platform) with documentation and testing a Gap	Other Than Satisfied	Same basis. Platform recovery capability does not establish that this system can be recovered, because no recovery procedure exists and none has been exercised.
SC-20	Inherited (Cloudflare); DNSSEC enablement Owner Input Required	Other Than Satisfied	A control element whose state is unknown at assessment time cannot be determined Satisfied. This resolves to Satisfied on confirmation that DNSSEC is enabled.

One determination is more favorable than a plain reading of the SSP would give. AC-8 is claimed as Implemented with a client-side display notice. For a consumer web application with no privileged interactive session, a display notice on the login and signup screens is the appropriate implementation of a system use notification, and the assessor concurs with Implemented rather than treating the absence of a server-enforced banner as a weakness.

6.4 Positive assessment observations

Three observations are recorded because they bear on the credibility of the control environment and would otherwise be lost in a report organized around weaknesses.

A functioning detect-and-correct cycle exists. Seven findings were self-identified and remediated during and immediately before the assessment period, several the same day they were found, including a broken-access-control condition in the paid access gate, a forgeable audit log, a length-only beta code check, and over-permissive EXECUTE grants on security-definer functions. A documented cycle of finding and closing real weaknesses is stronger evidence of an operating security practice than a clean initial assertion would be.

The SSP declares its own gaps. The implementation statements use present tense for what exists and name what does not, without aspirational language. This materially reduced assessment effort and is the behavior a control environment needs from its documentation.

Least privilege is enforced at the data layer, not only at the application layer. RLS, revoked INSERT on the audit table, and service-role-only EXECUTE mean that a compromise of the frontend does not by itself yield the data. This is the correct place to put the control and it is not the common choice at this system's scale.

---

7. Findings

Twenty findings, each mapped to the controls it affects. Every Other Than Satisfied result in Section 5 is covered by exactly one finding.

SAR-01 - Password length policy is bypassable through the raw signup endpoint

Risk: Moderate **Controls affected:** IA-5 **Condition.** The 12-character minimum and the HIBP breached-password check are enforced server-side in the `secure-signup` edge function. The underlying `/auth/v1/signup` endpoint remains reachable and is not subject to the length rule, because Lovable Cloud exposes no "before user created" hook. HIBP applies natively on both paths. **Effect.** An account can be created with a password shorter than the stated policy by calling the platform endpoint directly, defeating the stated authenticator strength requirement. **Cause.** Platform constraint. The enforcement point the owner controls sits beside, not in front of, the endpoint that needs it. **Recommendation.** Confirm whether Lovable Cloud can restrict or disable direct signup so that `secure-signup` is the only creation path. If it cannot, record the exposure as an accepted risk with the compensating HIBP check named, and re-evaluate on any platform change.

SAR-02 - Audit event set is not formally defined and audit records are not reviewed on a schedule

Risk: Low **Controls affected:** AU-2, AU-3, AU-5, AU-6, AU-12 **Condition.** The system logs authentication events and first-party analytics and alerts on one defined pattern, five or more login failures from one IP in 15 minutes, plus edge-function errors. There is no deliberated list of auditable events, no centralized generation across components, and no scheduled, documented human review. **Effect.** Activity outside the one alerting pattern is recorded but not looked at. Slow or low-volume abuse would persist undetected until it produced a visible symptom. **Cause.** No review cadence was defined; alerting was implemented in place of review. **Recommendation.** Write a short auditable-event list naming the events and their record content, and set a recurring review, monthly is proportionate at this scale, with the review date and the reviewer's conclusion recorded even when the conclusion is that nothing was found.

SAR-03 - No continuous monitoring strategy

Risk: Moderate **Controls affected:** CA-7, SI-4, SI-5 **Condition.** Monitoring consists of Cloudflare Analytics, first-party analytics tables, the `auth_events` record, and two alert triggers. There is no monitoring strategy, no defined metrics, no dashboard or SIEM, and no formal process for receiving and acting on provider security advisories. **Effect.** The system has no defined answer to what is watched, how often, and what threshold prompts action. Provider advisories reach the owner incidentally rather than through a process. **Cause.** Monitoring grew from the alerting work rather than from a strategy. **Recommendation.** Define a one-page monitoring strategy naming the metrics to be watched, their frequency, and the action threshold for each. Subscribe explicitly to the security advisory channels of Lovable, Cloudflare, Supabase, Stripe, and Anthropic and record where those notifications land.

SAR-04 - No contingency plan and no tested recovery procedure

Risk: Moderate **Controls affected:** CP-2, CP-4, CP-10 **Condition.** No written contingency plan exists, no plan test has been performed, and no documented recovery and reconstitution procedure exists. Platform recovery capability is inherited. **Effect.** In a platform outage, a data-destructive error, or an account lockout at a provider, recovery would be improvised. Recovery time and recovery point are undefined, so the owner cannot state what the business would lose. **Cause.** The plan was never

written. **Recommendation.** Write a contingency plan proportionate to the system: state a recovery time objective and a recovery point objective, name the recovery path for each provider dependency, and name the account-lockout contingency for each provider console. Test it once and record the result and the date.

SAR-05 - No independent backup and no tested restore

Risk: Moderate **Controls affected:** CP-9 **Condition.** Backups are platform-provided by Lovable Cloud. The owner performs no independent backup of application data and has never performed a restore. **Effect.** Backup existence is asserted by the provider and unverified by the owner. An untested backup is an assumption, not a control. A provider-side account or platform failure could take both the system and its only backups with it. **Cause.** Reliance on the managed platform without a residual owner action. **Recommendation.** Establish a scheduled export of the application tables to storage the owner controls independently of Lovable, then perform one restore into a scratch environment and record the date, the duration, and the outcome. This is the highest-value single item in this report relative to its effort.

SAR-06 - No incident handling procedure and no incident response plan

Risk: Moderate **Controls affected:** IR-4, IR-5, IR-6, IR-7, IR-8 **Condition.** An incident response policy exists in the policy manual. No incident handling procedure, no incident monitoring or tracking mechanism, no reporting procedure with recipients and timeframes, and no written incident response plan exist. Section 9 of the SSP records several same-day remediations, which demonstrates capability without a defined process. **Effect.** Incident handling depends entirely on the owner's judgment in the moment. Breach notification obligations to affected users under Idaho law and to providers under their terms have no defined trigger, recipient, or timeframe. **Cause.** The policy was written; the plan and procedure beneath it were not. **Recommendation.** Write a short incident response plan covering detection, categorization, containment, eradication, recovery, and post-incident review, with an explicit notification section naming who is told, by when, and by what method for each incident category. Keep an incident log even when the count is zero.

SAR-07 - Security categorization and risk assessment are asserted, not documented

Risk: Low **Controls affected:** RA-2, RA-3, RA-7 **Condition.** The LOW categorization is owner-asserted with no documented FIPS 199 exercise. No formal risk assessment exists. Risk response is ad hoc. **Effect.** The baseline selection rests on an undocumented judgment. If the judgment is wrong, for example if the PII in the demographics submissions carries more impact than assumed, the entire control set is calibrated to the wrong level and nothing in the documentation would catch it. **Cause.** The categorization was made implicitly at the start rather than as a recorded step. **Recommendation.** Document the FIPS 199 categorization explicitly: name each information type, assign confidentiality, integrity, and availability impact, and state the rationale, particularly for the demographics and chat content. Then write a risk assessment that lists the threat sources that actually apply to a small consumer web application and the likelihood and impact of each.

SAR-08 - No configuration baseline, no security impact analysis, and an incomplete inventory

Risk: Low **Controls affected:** CM-2, CM-4, CM-6, CM-7, CM-8 **Condition.** No documented configuration baseline exists and no security impact analysis step precedes a change. The component inventory in the SSP is current but has two unresolved items, the seventh Cloudflare domain and the `empty-disk-1010` Worker. **Effect.** There is no recorded known-good state to compare against or revert to after an unwanted change, and security-relevant changes can ship without a deliberate review step. An inventory with unidentified components cannot support a complete boundary assertion. **Cause.** Change control is informal because there is one person making the changes. **Recommendation.** Capture the current security-relevant settings as a baseline document, including auth settings, RLS policies, grants, cron jobs, rate limits, and edge-function configuration, and record the date. Add a one-line security impact note to the change record for any change touching the baseline. Resolve the two inventory items.

SAR-09 - Rate limiting is per-instance and there is no WAF ruleset

Risk: Low **Controls affected:** SC-7 **Condition.** Application rate limits on the magic-token endpoint (10 per minute) and the contact endpoint (3 per minute) are enforced per edge-function instance rather than by a distributed limiter. Cloudflare provides edge DDoS protection; no application-layer WAF ruleset is configured. **Effect.** A distributed attacker spread across enough edge-function instances receives a higher effective limit than the stated one. The controls blunt brute force but do not bound it. **Cause.** Per-instance state is what the edge-function runtime provides by default. **Recommendation.** Move the counters to the database or another shared store so the limit is global, and enable Cloudflare rate limiting rules at the edge in front of the auth and contact paths, which enforces above the instance layer at no additional integration cost.

SAR-10 - Six transitive dependency vulnerabilities remain with no upstream patch

Risk: Low **Controls affected:** RA-5, SI-2 **Condition.** A dependency scan found 13 known vulnerabilities. Upgrades and npm overrides reduced these to 6. The remaining 6 are transitive with no patched upstream release, in the recharts-bundled `lodash`

and in `@lovable.dev/mcp-js` build tooling. Application-side remediation is active but not scheduled. **Effect.** Known vulnerable code is present in the build. Exploitability is low because the affected paths are a charting library's bundled utility and build-time tooling that does not execute in production. **Cause.** Transitive dependency with no maintainer fix available. **Recommendation.** Retain as accepted monitored residuals with the rationale recorded, which is the correct disposition. Add a recurring dependency scan on a fixed cadence so the acceptance is re-evaluated rather than assumed, and re-check for an upstream release at each scan.

SAR-11 - No dependency end-of-support calendar

Risk: Low **Controls affected:** SA-22 **Condition.** Dependency versions and vulnerabilities are scanned. No calendar tracks the end-of-support date of each component or platform. **Effect.** A dependency can pass from supported to unsupported without the transition being noticed, at which point vulnerability scanning stops producing fixes. **Cause.** Not tracked. **Recommendation.** Add end-of-support dates for the runtime, framework, and major dependencies to the same document as the component inventory, and review them at the annual policy review.

SAR-12 - No independent assessment, no dated POA&M, and no authorization record

Risk: Low **Controls affected:** CA-2, CA-5, CA-6 **Condition.** This report is the first structured assessment and it is a self-assessment. Prior to it, the SSP gap list served as an informal plan of action with no dates and no owners. No formal authorization decision record exists. **Effect.** Weaknesses have no completion commitment, so they persist by default rather than by decision. Risk acceptance is implicit and undated. **Cause.** The assessment and authorization process had not been performed. **Recommendation.** Adopt the POA&M in Section 8 as the standing gap register with the target dates accepted or revised by the owner. Record a dated authorization decision stating that the owner accepts the residual risk described in this report, and re-authorize at the annual review or on any significant change. This finding closes on acceptance of Section 8.

SAR-13 - No documented account review cycle and no access agreement for the second account

Risk: Low **Controls affected:** AC-2, PS-6 **Condition.** Two accounts exist, belonging to the owner and a marketing collaborator. There is no documented account review cycle and no confirmed written access or confidentiality agreement covering the collaborator. **Effect.** Access held by a non-owner is undocumented and unbounded in time, with no recorded obligation on the holder and no scheduled point at which the access is reconsidered. **Cause.** Informal working relationship at a two-account scale. **Recommendation.** Put a short written access and confidentiality agreement in place for the collaborator naming what the access covers and what happens on termination, and add a semiannual account review to the same schedule as the audit review in SAR-02.

SAR-14 - External connections are governed only by provider terms of service

Risk: Low **Controls affected:** AC-20, CA-3, SA-4, SA-9, SR-2, SR-3, SR-5, SR-11 **Condition.** Interconnections with Anthropic, Stripe, Resend, Cloudflare, Proton, and Zoom are documented in the SSP and governed by each provider's standard terms. There is no policy governing use of external systems, no interconnection security agreements, no supply chain risk management plan, and no provider attestations on file. **Effect.** Provider security posture is assumed rather than evidenced. A provider's material change to its terms or its security practices would not necessarily surface. This is also the condition behind the inherited-control limitation in Section 3. **Cause.** Standard terms are the only agreement available to a customer of this size, which is a real constraint, but the absence of attestations on file is not. **Recommendation.** Obtain and file the publicly available compliance reports or trust-center attestations for Lovable, Cloudflare, and Stripe, which converts 25 inherited controls from assumption to evidence. Write a short external systems policy naming each provider, the data it receives, and the review trigger. A full supply chain risk management plan is disproportionate at this scale; state that determination rather than leaving the control silent.

SAR-15 - System development lifecycle and system documentation are informal

Risk: Low **Controls affected:** SA-3, SA-5 **Condition.** The development lifecycle is owner-run and informal. System documentation consists of the SSP and referenced provider documentation. **Effect.** Security considerations enter the build through the owner's practice rather than through defined lifecycle steps, so their application is consistent only as long as the owner's attention is. **Cause.** Single-operator development with no process artifact. **Recommendation.** Record the lifecycle actually followed, even if it is four steps, and name where the security review step sits in it. Proportionality matters more than formality here.

SAR-16 - Account lockout threshold is not owner-configurable

Risk: Low **Controls affected:** AC-7 **Condition.** Failed logins are throttled by Supabase Auth. The owner cannot configure a lockout threshold or duration because Lovable Cloud does not expose those settings. The application logs `login_fail` events with source IP and alerts on five failures from one IP within 15 minutes. **Effect.** The lockout behavior protecting accounts is

unknown to the owner in its specifics and cannot be tuned to the owner's stated policy. **Cause.** Platform constraint, not an implementation decision. **Recommendation.** Record this as an accepted platform constraint with the alerting named as the compensating control. Ask Lovable to confirm the applied throttling values and file the answer as evidence. Re-evaluate if the platform later exposes the settings.

SAR-17 - Internal connection authorization is not documented

Risk: Low **Controls affected:** CA-9 **Condition.** Internal connections between the frontend, the edge functions, and the database are authorized in effect by RLS and by the grants on the security-definer functions. The authorization is not documented as such. **Effect.** The control is operating but cannot be demonstrated from documentation alone, which matters when the assessor and the implementer are not the same person. **Cause.** The enforcement is in the schema rather than in a document. **Recommendation.** Add a short internal connections table to the SSP listing each connection, its data, and the mechanism that authorizes it. This is close to a documentation-only fix.

SAR-18 - Software license inventory is not maintained

Risk: Low **Controls affected:** CM-10 **Condition.** Components are used within their license terms. No inventory of components and their licenses is maintained. **Effect.** License compliance is asserted without a record supporting it. **Cause.** Not tracked. **Recommendation.** Generate a license report from the dependency manifest and store it alongside the component inventory. This is a single command and a filed output.

SAR-19 - Malicious code protection relies on input typing and platform controls

Risk: Low **Controls affected:** SI-3 **Condition.** The system accepts text-only input, tracks spam attempts and a suppression list, and inherits malicious code protection from the hosting infrastructure. There is no file upload path. **Effect.** The exposure is genuinely small because there is no execution path for uploaded content. The residual concerns prompt-injection and abusive content entering the AI path and the support handoff, which is not a malware condition and is not addressed by malware controls. **Cause.** Correct scoping for the architecture; the control is thin because the threat is thin. **Recommendation.** State the no-upload architecture explicitly as the basis for the control and record the spam and suppression mechanisms as the operative protection. If a file upload path is ever added, this finding is reopened before that path ships.

SAR-20 - Boundary items unresolved pending owner confirmation

Risk: Low **Controls affected:** SC-20, SR-12 **Condition.** Two items remain unconfirmed. DNSSEC status for `communitytechaid.ai` is unknown at assessment time. The Cloudflare Worker `empty-disk-1010`, with 0 invocations, has an undetermined boundary status and has not been removed or documented. **Effect.** A control whose state is unknown cannot be determined Satisfied. An unidentified deployed component is an unassessed component. **Cause.** Both items were raised in the SSP as owner-input-required and were still open at the close of the assessment period. **Recommendation.** Confirm and enable DNSSEC if it is not enabled. Determine whether the Worker is in the boundary; if it is not, delete it and record the disposal. Both are short tasks and both close their controls outright.

---

8. Plan of Action and Milestones (POA&M)

Target dates are assessor-recommended and require owner acceptance to become commitments. They are set relative to the report date of 2026-07-27 and are ordered by risk and by effort, so that the items that most reduce exposure per hour spent come first. The owner is the responsible party for every item; the column is retained because a POA&M without an accountable name is not a POA&M.

ID	Finding	Controls	Risk	Recommended action	Owner	Target date	Status
P-01	SAR-05	CP-9	Moderate	Establish an owner-controlled export of application tables; perform and record one test restore	Owner	2026-08-31	Open
P-02	SAR-06	IR-4, IR-5, IR-6, IR-7, IR-8	Moderate	Write the incident response plan and handling procedure, including notification triggers, recipients, and timeframes; start an incident log	Owner	2026-09-15	Open
P-03	SAR-04	CP-2, CP-4, CP-10	Moderate	Write the contingency plan with RTO and RPO; document the recovery procedure; perform and record one test	Owner	2026-09-30	Open
P-04	SAR-01	IA-5	Moderate	Determine whether direct signup can be restricted; if not, record as accepted risk with the HIBP compensating control named	Owner	2026-08-15	Open
P-05	SAR-03	CA-7, SI-4, SI-5	Moderate	Write a one-page continuous monitoring strategy with metrics, frequency, and thresholds; subscribe to and record provider advisory channels	Owner	2026-09-30	Open
P-06	SAR-20	SC-20, SR-12	Low	Confirm and enable DNSSEC; resolve or delete the `empty-disk-1010` Worker and record the disposal	Owner	2026-08-10	Open
P-07	SAR-14	AC-20, CA-3, SA-4, SA-	Low	Obtain and file provider attestations for Lovable, Cloudflare, and Stripe;	Owner	2026-10-15	Open

		9, SR-2, SR-3, SR-5, SR-11		write a short external systems policy; record the supply-chain proportionality determination			
P-08	SAR-02	AU-2, AU-3, AU-5, AU-6, AU-12	Low	Define the auditable event list and record content; start a monthly audit review with recorded date and conclusion	Owner	2026-09-15	Open
P-09	SAR-08	CM-2, CM-4, CM-6, CM-7, CM-8	Low	Capture the security configuration baseline; add a security impact note to the change record; resolve the two inventory items	Owner	2026-10-15	Open
P-10	SAR-09	SC-7	Low	Move rate-limit counters to shared storage; enable Cloudflare rate limiting rules on the auth and contact paths	Owner	2026-09-30	Open
P-11	SAR-07	RA-2, RA-3, RA-7	Low	Document the FIPS 199 categorization with rationale per information type; write a proportionate risk assessment	Owner	2026-10-31	Open
P-12	SAR-13	AC-2, PS-6	Low	Execute a written access and confidentiality agreement for the collaborator; add a semiannual account review	Owner	2026-09-15	Open
P-13	SAR-10	RA-5, SI-2	Low	Formalize acceptance of the 6 residual vulnerabilities with rationale; schedule a recurring dependency scan	Owner	2026-08-31	Open
P-14	SAR-12	CA-2, CA-5, CA-6	Low	Accept or revise this POA&M; record a dated authorization decision accepting residual risk	Owner	2026-08-15	Open
P-15	SAR-16	AC-7	Low	Request the applied throttling values from Lovable and file the response; record the constraint as accepted with alerting as compensating	Owner	2026-09-30	Open
P-16	SAR-11	SA-22	Low	Add end-of-support dates for the runtime, framework, and major dependencies to the component inventory	Owner	2026-10-31	Open
P-17	SAR-17	CA-9	Low	Add an internal connections table to the SSP naming each connection and its authorizing mechanism	Owner	2026-09-30	Open
P-18	SAR-18	CM-10	Low	Generate and file a component license report from the dependency manifest	Owner	2026-08-31	Open
P-19	SAR-15	SA-3, SA-5	Low	Record the development lifecycle actually followed and name where the security review step sits	Owner	2026-10-31	Open
P-20	SAR-19	SI-3	Low	Record the no-upload architecture as the control basis; reopen before any file upload path ships	Owner	2026-09-30	Open

8.1 Closure criteria

An item closes when the artifact it names exists, is dated, and is referenced from the SSP, and when any test the item requires has been performed and its result recorded. Writing a plan closes the planning control; it does not close the testing control. Items P-01, P-03, and P-13 each require a performed action, not only a document.

8.2 Recommended sequencing

P-06, P-04, P-14, and P-18 are short and close controls outright; they are the first pass. P-01 is the single highest-value item in the report and should not wait behind documentation work. P-02 and P-03 are the largest writing tasks and carry the largest share of the open Moderate risk. P-07 converts 25 inherited controls from assumption to evidence and is the highest-leverage documentation item.

---

9. Assessor Conclusion

The controls that protect the data are implemented and, where they could be exercised, they work. Access enforcement, authentication, audit integrity, and least privilege at the data layer were tested and satisfied. Seven weaknesses were found and closed during and immediately before the assessment period, which is direct evidence of a working correction cycle rather than an asserted one.

The controls that would let the system survive a bad day are not in place. Contingency planning, incident response, backup verification, and continuous monitoring are the concentration of open Moderate risk, and they share a cause: the system was engineered carefully and governed informally. None of the four requires a purchase or a platform change. Each requires a document and, in two cases, a single test.

The largest evidentiary weakness in this report is not a control at all. Twenty-five inherited controls rest on provider representation with no attestation on file, in a hosting model where the owner cannot independently verify them. Filing the available provider attestations is the cheapest material improvement available to this control environment.

The residual risk to a LOW-categorized consumer application processing LOW-impact PII is acceptable for continued operation, on the condition that the Moderate-risk items in Section 8 are worked to their target dates. This is the assessor's determination. Formal acceptance of the residual risk is the owner's decision under CA-6 and is recorded by item P-14.

Appendix A - Assessment Method Coverage

Examine and Interview were applied to all 136 controls. Test was applied to the following 24 controls, where a behavior could be exercised and observed:

AC-2, AC-3, AC-8, AC-14, AC-17, AU-2, AU-5, AU-6, AU-9, AU-11, AU-12, CM-6, CM-7, IA-5, IA-8, IA-11, RA-5, SA-8, SC-5, SC-8, SC-28, SI-2, SI-12, SR-3.

Appendix B - Evidence Sources

- SSP: NIST SP 800-53 Rev 5 LOW Baseline Control Implementation Statements, revised 2026-07-27
- Community Tech Aid Security Policy Manual v1.0, effective 2026-07-27
- Application and edge-function source: `ChatAccessGate`, `useIdleLogout`, `validatePaidTokenWithServer()`, `supabase/functions/chat/index.ts`, `log-auth-event`, `log-analytics`, `verify-paid-session`, `secure-signup`, `_shared/security-alert.ts`
- Database: table schemas, RLS policies, role grants and revocations, `pg_cron` retention jobs, `count_recent_login_fails` RPC
- Provider console configuration: Supabase Auth settings exposed through the Lovable editor, Cloudflare DNS and edge settings, Stripe checkout configuration, Resend sending configuration
- Public site content: `/terms`, `/privacy`, login and signup system-use notice
- Dependency scan output, 2026-07-27

Appendix C - Not Applicable Determinations

Eighteen controls were determined Not Applicable. The determinations fall into four groups, each resting on a factual property of the organization rather than on a decision not to implement.

Basis	Controls
No workforce, no employees or contractors	AT-2, AT-3, AT-4, CP-3, IR-2, PS-2, PS-3, PS-4, PS-5, PS-8, PS-9
No owned facility or organization-operated network	AC-18, PE-5
No organization-managed endpoints or removable media	AC-19, MP-7
No system-controlled collaborative devices or owner-operated resolver	SC-15, SC-21
Withdrawn in Rev 5	PE-7

Each determination is reversible. Adding a first employee reopens the PS, AT, and IR training controls. Adding managed devices reopens AC-19 and MP-7. The determinations are properties of the organization as it exists on the report date, not permanent exclusions.

End of report. This assessment was performed by the system owner as a self-assessment against NIST SP 800-53A Rev 5 assessment methods, covering the NIST SP 800-53 Rev 5 LOW baseline as enumerated in the system security plan. It states what was examined and tested, where the assessor's determination differs from the plan, and what remains open, with dates.